



ITCY470: IT Auditing & Business Continuity

Dr. Ghassan Mohamed Alkoureiti

First Semester 2025-2026

An Audit Plan and Audit Program for Tesla, Inc..

Aljazi Ali Almujaaddam - 202202227

Dana Hussain Alhayki - 202204341

Manar Hussain Abdulrahim - 202201554

Noora Abdulrahman Bumajaid - 202203245

Sec 01

Submission Date: November 30, 2025

Table of content

Table of content.....	2
1. The Audit Plan.....	3
1.1 Company Overview.....	3
1.2 The IT Audit Universe.....	5
1.3 Risk Assessment.....	7
Table 1: Risk Assessment Matrix for Tesla’s IT Audit Universe.....	8
Table 2: Prioritized IT Audit Areas for Audit Plan.....	12
1.5 Audit Plan.....	14
Table 3: Annual IS Audit Plan Schedule (Year 1).....	14
2. The Audit Program.....	16
2.2 Audit Scope.....	17
2.3 Client Controls.....	18
2.4 Audit Criteria.....	19
2.5 Audit Schedule & Resourcing.....	20
2.6 Evidence Gathering Techniques.....	22
3. Proposed Test of Controls Audit Procedures.....	23
Table 4: Detailed Test-of-Controls Procedures for Key Client Controls.....	23
4. The Audit Team.....	28
4.1 Audit Team Roles.....	28
4.2 Audit Team Qualifications.....	29
4.3 Audit Team Responsibilities.....	30
5. Additional Components.....	31
References.....	33

1. The Audit Plan

This section outlines Tesla's yearly IS audit strategy. A brief overview of the company opens the document, followed by the identification of technology areas under review. Next, risks are assessed through a structured approach focused on five core impacts. Based on this ranking, audits target zones with the most serious potential damage. Flexibility is built in, priorities adjust as threats evolve, or objectives shift. This approach uses established frameworks such as ISO/IEC 27001 and COBIT 2019, combined with the NIST Cybersecurity Framework, ensuring audits address critical aspects while emphasizing supervision. Designed to align with stakeholder expectations, it supports security assessments based on actual threats.

1.1 Company Overview

Tesla goes beyond vehicles, operating as a complete clean energy company. Founded in 2003, it aims to accelerate the shift to sustainable power. Facilities are located worldwide major ones in Texas, Shanghai, and close to Berlin. As of 2024, over 140,000 employees were part of Tesla. Operations focus on two areas: building electric cars while also generating and saving solar energy.

The automotive segment includes producing, engineering, delivering, and leasing out electric vehicles such as Model S, Model 3, X, Y, Cybertruck, and Tesla Semi, as well as handling vehicle-linked incentives. Rather than relying on traditional dealerships, this division operates through a direct-to-customer model that links makers with users directly.

On the energy side, generation and storage consist of manufacturing, installing, constructing, offering, or renting solar technology plus battery solutions like Powerwall, Powerpack, and Megapack tailored for households, companies, and large-scale power providers.

Tesla operates unlike typical automakers, producing key parts internally. Rather than depending on external vendors, it develops batteries, motors, and code independently. Staff are grouped by role: some work on car styling, others manage manufacturing; meanwhile, separate units handle sales, service, power solutions, or autonomous driving features.

The technology powering Tesla's operations is complex yet crucial for achieving results. Key components include:

1. Fabrication plus delivery systems rely on custom software - modified SAP tools - to manage daily production, logistics, and inventory at Tesla's major international factories (Tesla, 2023).
2. Car systems use unique software updates that come through wireless signals, delivering new features via remote access, improving performance with fixes that resolve issues instantly.
3. Autopilot, combined with autonomous systems, uses vast computer clusters such as Do8o - to train on real-world driving info collected daily by Tesla vehicles navigating streets.
4. A robust global system connects manufacturing units, retail outlets, service centers also integrates sites that operate essential programs while storing vast data on vehicle performance, customer information, and output history.
5. The Tesla app or website allows customers to purchase vehicles, customize options, schedule service, handle solar equipment, plus monitor charging expenses remotely.
6. Cybersecurity relies on multiple levels to protect intellectual property, such as power cell blueprints or digital tools, not only blocking hackers from accessing vehicles but also safeguarding personal data.

Navigating a large IT environment brings serious challenges, securing countless distributed IoT devices, protecting sensitive AI systems, ensuring self-driving functions remain stable and secure, along with meeting demanding regulations such as GDPR, CCPA, and global automotive safety standards. At Tesla, the IS audit approach must directly address every one of these complex, critical risks.

1.2 The IT Audit Universe

The IT Audit Universe at Tesla includes key technologies, processes, and systems linked to company objectives, which are examined during review cycles. Because Tesla moves quickly, a wide-angle view allows the audit strategy to stay adaptive. Shown next are the core areas that shape Tesla's IT audit priorities

1. Vehicles operate using software requiring frequent updates. Therefore, teams design each improvement cautiously via verification steps prior to launch. After approval, electronic seals verify its safety for global distribution. In case intruders access this network, they could deploy damaging code from a distance. This threat demands that every phase prevent unapproved modifications efficiently.
2. Autopilot/AIDataPipeline – Pulling vehicle information from cars, securing it during storage, and applying insights responsibly. This covers protecting learning environments such as Dojo, where artificial intelligence improves. In case intruders gain access, they could alter decisions made by autonomous vehicles - resulting in risky conditions while driving.
3. Manufacturing & Supply Chain Systems (ERP/MES) SAP's integrated ERP runs together with a tailored MES to manage core operations, sourcing supplies, producing goods, and delivering orders. When issues arise, these can halt production, disrupt financial records, or leak confidential manufacturing data.

4. Global network security includes Tesla's main systems, data centers, along web platforms such as AWS or Azure, where vital services and records are hosted. It relies on firewalls, detection mechanisms to spot threats or block them, combined with segmented areas for added defense.
5. Cybersecurity for factory machines is crucial - these setups manage large-scale manufacturing processes. When safeguards on industrial devices fail, attackers may halt activities or disrupt workflows. Issues can emerge physically, such as malfunctions or damaged components. In addition, cybercriminals might steal confidential methods Tesla uses to produce batteries.
6. Tesla collects large amounts of personal data driving patterns, locations, and video recordings. While European, Californian, and Chinese regulations require strict compliance, this section examines adherence. Data handling practices come under review; user consent is assessed for validity. Information transfers across regions are analyzed separately. Each step considers a real-world application rather than policy alone.
7. Identity and Access Management controls entry to essential systems - such as design software or production equipment - using a central system. This matters since access is restricted strictly to necessary resources, reducing internal threats by limiting user permissions.
8. Securing the Tesla app along with user profiles is crucial - these features allow remote locking, unlocking, and even operating vehicles. Should attackers discover flaws, they could take control of a vehicle, monitor activity, or access confidential details. Strong security measures aren't just helpful - they're required right from the start.
9. IT oversight tied to business goals ensures tech efforts support broader objectives. Through structured policies, risk controls are managed effectively. Spending on

technology aligns with Tesla's growth pace and innovation drive - possibly assessed using COBIT 2019 standards.

10. Incident Response combined with Business Continuity: Assesses Tesla's preparedness against cyber risks - such as data breaches or ransomware - and maintains essential operations, including vehicle software upgrades and manufacturing flow. Speed of reaction counts equally alongside uptime during incidents. Plans must perform reliably when stress levels rise. Live trials reveal whether backup systems survive major system shocks. Fast restoration helps factories stay active following sudden tech failures.

This particular focus allows the audit group to address Tesla's key technology gradually - concentrating on components where failure might most affect safety, earnings, or reputation.

1.3 Risk Assessment

The audit plan centers on risk, guided by tips from ISACA and also IIA. That means checking target areas with the highest dangers. When tech changes, the method shifts, while staying aligned with business aims while meeting rules. The bottom line is to focus energy where risks are strongest.

Each piece of the IT audit was reviewed based on how likely controls might break, while factoring in potential impacts from five separate viewpoints

F/S Impact: Could affect income summaries or profits. A high level (3) may cause major mistakes in reporting; medium (2), noticeable yet doesn't shift the final outcome much; low (1), hardly changes financial details.

Internal Control Quality (I/C Quality): How strong are the current strength of protections. A rating of 3 suggests defenses are shaky or just starting out; meanwhile, a 2 points to fair security though gaps remain; whereas a 1 reflects systems that are robust, tested, running smoothly.

Confidentiality: Could be serious, like client records, inventions, or internal strategies, which is level 3. Mild concern for internal business info, where they're not super critical, are considered 2. When there's barely any exposure, it hardly matters, we mark it 1.

Integrity: When information is altered from unauthorized access or by accident. High (3): can seriously disrupt major operations, like glitches in autonomous vehicle software or AI models. Medium (2): may cause disruptions in processes, where tasks take longer. Low (1): hardly has an impact, where daily routines keep running smoothly.

Availability: When systems crash, unauthorized access is key. Rank 3 halts all operations, like manufacturing or patches; rank 2 fixes are manageable while still running; rank 1 is not business-critical.

Likelihood was rated 1 to 3 - where 1 means rare, 3 means frequent. In every area, the risk value came from this calculation: **Likelihood × (Sum of the five impact scores)**. This approach helps keep it even and reliable across the board.

The analysis came from checking how Tesla's risks compare in the industry, especially since its AI and battery systems hold serious value, though software bugs might create safety problems, on top of complicated global regulations. Key dangers include ongoing cyberattacks trying to access data, strong reliance on error-free programming, along with managing tight data privacy laws in various regions.

Table 1: Risk Assessment Matrix for Tesla's IT Audit Universe

IT Audit Area	Likelihood	F/S Quality	I/C Quality	Confidentiality	Integrity	Availability	Risk Score
Autopilot/AI	High (3)	2 (Med)	2 (Med)	3 (High)	3 (High)	2 (Med)	36

Data & Model Training							
Vehicle Software & FOTA Management	High (3)	2 (Med)	2 (Med)	3 (High)	3 (High)	3 (High)	39
Manufacturing & Supply Chain (ERP/MES)	High (3)	3 (High)	2 (Med)	2 (Med)	3 (High)	3 (High)	39
Cybersecurity for OT (Gigafactories)	Med (2)	3 (High)	2 (Med)	3 (High)	3 (High)	3 (High)	28
Global Network & Cloud	High (3)	2 (Med)	2 (Med)	3 (High)	2 (Med)	3 (High)	36

Security							
Data Privacy & Protection Compliance	Med (2)	2 (Med)	2 (Med)	3 (High)	2 (Med)		20
Identity & Access Management (IAM)	Med (2)	2 (Med)	2 (Med)	3 (High)	2 (Med)	2 (Med)	22
Customer Digital Platforms Security	Med (2)	2 (Med)	2 (Med)	3 (High)	2 (Med)	2 (Med)	22
IT Governance &	Med (2)	2 (Med)	2 (Med)	2 (Med)	2 (Med)	2 (Med)	20

Strategic Alignment							
Incident Response & Business Continuity	Med (2)	2 (Med)	2 (Med)	2 (Med)	2 (Med)	3 (High)	22

Risk Score = Likelihood × (F/S Impact + I/C Quality + Confidentiality + Integrity + Availability)

The findings point straight to **Vehicle Software & FOTA Management** and **Manufacturing & Supply Chain Systems** as key concerns, mainly because they impact safety, revenue, and operational continuity. **Autopilot/AI Data & Model Training** and **Global Network & Cloud Security** follows closely due to confidentiality and integrity implications. That ranking offers a solid, fact-based path for deciding what audits to take on the upcoming cycle.

1.4 Prioritized IT Audit Universe Areas

After checking the risks, we rank IT audit universe areas by how serious each issue is. Even though the risk number matters most, things like legal rules, board requests, or limited staff play

a role too. That way, we end up with a realistic lineup of checks that can actually be executable each year.

Table 2: Prioritized IT Audit Areas for Audit Plan

Priority	IT Audit Area	Risk Level	Rationale for Priority
1	Vehicle Software & FOTA Management	High	Highest risk score (39). A security or integrity failure in this system could lead to safety incidents, vehicle immobilization, or a fleet-wide recall. This is a unique and critical system for Tesla, warranting top priority.
2	Manufacturing & Supply Chain (ERP/MES)	High	Tied highest risk score (39). Core to financial reporting and global production. A failure could halt manufacturing, disrupt the supply chain, and lead to material financial misstatement.
3	Autopilot/AI Data & Model Training	High	High risk (36). Protects Tesla's most valuable IP and ensures the safety of autonomous driving systems. A breach or manipulation could have catastrophic reputational and safety consequences.
4	Global Network & Cloud Security	High	High risk (36). The backbone of all operations. A network breach could compromise every other system. Prioritized due to the pervasive threat of cyberattacks

			and the critical need for data confidentiality and availability.
5	Cybersecurity for OT (Gigafactories)	Med-High	High impact score, moderate likelihood (28). Addressed in Year 1 due to the potential for physical damage and production stoppage. The convergence of IT and OT networks increases its relevance.
6	Data Privacy & Protection Compliance	Medium	Moderate risk (20), but mandatory due to stringent global regulations (GDPR, PIPL). Non-compliance risks massive fines and reputational damage. Scheduled as a compliance-focused audit.
7	Identity & Access Management (IAM)	Medium	Medium risk (22). Foundational control that affects all systems. An audit here can identify systemic weaknesses and provide assurance for other, application-specific audits.
8	Incident Response & Business Continuity	Medium	Medium risk (22). Critical for organizational resilience. This audit will test Tesla's preparedness for a major cyber or operational incident.
9	Customer Digital Platforms Security	Medium	Medium risk (22). Important for customer trust and preventing vehicle theft via the app, but considered slightly less critical than infrastructure and core manufacturing systems. (<i>Deferred</i>)

10	IT Governance & Strategic Alignment	Medium	Medium risk (20). Essential for long-term health, but the audit can be deferred as other areas address more immediate operational risks. (<i>Deferred</i>)
----	-------------------------------------	--------	--

This ranking shows how numbers meet real-world needs. The first five spots go straight into next year's audit schedule. The ones deferred will get another look by Year 2, but could move up fast if leaders request or new risks arise.

1.5 Audit Plan

The audit plan turns top risks into a realistic yearly schedule that fits within limited resources. Using a team of five people and about 1,000 workdays total, it assigns staff and hours to key tasks first. Instead of waiting, major threats get attention up front, while maintaining flexibility if unplanned events occur.

Table 3: Annual IS Audit Plan Schedule (Year 1)

Quarter	Audit Engagement	Planned Effort	Team Allocation
Q1	Vehicle Software & FOTA Management Audit – Comprehensive review of the software development lifecycle, code signing, update distribution, and security controls.	~160 auditor-days	Four-person team (specialists in software security, embedded systems, and cryptography). Engagement lasts 10-12 weeks.
Q2	Manufacturing & Supply Chain (ERP/MES) Audit – Deep dive into application controls, data integrity, system	~150 auditor-days	Four-person team (ERP specialists, ITGC auditors, and a

	integrations, and access management within the SAP and MES environments.		manufacturing process expert). Runs 10 weeks.
Q3	Autopilot/AI Data & Model Training Audit – Evaluation of the data pipeline security, model training environment, and AI governance framework.	~140 auditor-days	Three-person team (data scientists, AI ethics/security specialists). Lasts 8-10 weeks.
Q4	Global Network & Cloud Security Audit – Assessment of network architecture, firewall rules, IDS/IPS, and cloud security configurations.	~130 auditor-days	Three-person team (network and cloud security experts). Runs 8-9 weeks.
Q5	Cybersecurity for OT (Gigafactories) Audit – Review of ICS/SCADA security, network segmentation, and physical controls in one major Gigafactory.	~80 auditor-days	Two-person team (OT security specialists). Conducted concurrently with Network audit if resources allow.
Carry-Forward	Data Privacy & IAM Audits – These will be scheduled in Year 2, or initiated in Q4 if Q3/Q4 audits conclude early.	N/A	Resources dependent on availability.

The full workload set for Year 1 is around 660 auditor-days, so there's a spare 340 days left over. This time can go toward admin work, learning sessions, checking up on past audit results, or handling sudden review requests that come from leadership or the Audit Committee.

The timeline takes company rhythms into account - like setting the ERP check for Q2 so it doesn't hit during year-end number crunching. Tough spots such as Vehicle Software get reviewed early, giving leaders more room to fix serious issues if they pop up. Before moving forward, top executives at Tesla along with the Audit Committee must sign off on the layout, making sure everyone's on board and teams can do their work without roadblocks.

2. The Audit Program

This section outlines the audit method for the main yearly focus checking vehicle software and FOTA update procedures. The model may later be adapted for comparable evaluations. Influenced by established methods, it aligns with standards from ISO/IEC 27001, COBIT 2019 (connected to APO12, DSS05, and DSS06), as well as parts of NIST CSF.

2.1 Audit Objectives

The primary aim of this analysis is to provide impartial assurance that techniques for developing, securing, and distributing automotive software alongside Firmware Over-the-Air (FOTA) updates are resilient, secure, yet reliable. Instead of assuming safety, it verifies whether protective measures prevent unauthorized modifications, maintain code integrity, shield drivers, or safeguard personal data. Major objectives include:

1. Evaluate SDLC security through checks in development, testing, or staging environments for vehicle software - assess methods used to review code, monitor defects, yet apply supervisory controls rather than just restricting repository access.
2. See how secure the FOTA system really is: Verify if firmware updates use correct cryptographic signatures, look into how well update servers are shielded, while assessing connection stability from Tesla's network to vehicles during transfers.

3. Review access policies along with role division: Verify that only authorized users can reach critical systems - such as code signing or deployment environments - and ensure development, testing, and release tasks are handled by separate individuals.
4. Review how incidents are managed and backup actions taken: Ensure reliable ways exist to detect problems, respond promptly while restoring functionality following a problematic update, with swift rollback to prior stable firmware when necessary.
5. Review compliance with internal policies and external standards: make sure the FOTA approach matches Tesla's security guidelines along with recognized automotive cybersecurity models - like ISO 21434 or SAE J3061 - to support reliable safety results.

2.2 Audit Scope

This review includes only people working with car software and updates, such as team members, techniques, and technology, to enable close analysis. Focusing on particular stages of the workflow, it prioritizes an in-depth understanding instead of wide coverage by examining change handling carefully. Even though the scope is narrow, the method allows clear views of activities via firsthand monitoring. With emphasis placed on core elements like release procedures or digital infrastructure, results tend to mirror actual operation more precisely.

In Scope:

Software is built first; then integrated with system components. A finalized version gets selected afterward. Encryption protects the release before distribution. Updates are pushed to devices using secure channels. Installation success is verified automatically. If issues arise, rollbacks occur immediately.

Source code systems such as Git, CI/CD pipelines, firmware signature methods, FOTA server infrastructures, along with delivery networks; additionally, the onboard update component.

Data consists of firmware files, encryption keys, along update rights linked to specific vehicles, maintaining precision while protecting information in every part.

Software developers, along with release managers and SREs, are involved in FOTA tasks security experts contribute too. And the Locations have a key center managing FOTA operations, focusing on online access rather than physical location.

Out of Scope:

The functioning dependability of a vehicle's central control unit, measured via targeted risk assessments such as ISO 26262, is crucial. Although conformity audits are in place, field effectiveness relies on steady evaluation methods. As guidelines shape engineering decisions, following them can lower dangers in daily operation.

In cases where execution falls short, threats might rise without warning. Given how fast innovations emerge, assessment intervals should adapt just as quickly.

The security of a vehicle's electronic control units outside FOTA processes is assessed under different scenarios. When looking at individual operations, factors change based on outside elements unrelated to software distribution methods. The making of physical components using manufacturing methods.

A full check of the vehicle's internal network (CAN bus), unless a weakness in the FOTA update shows a direct path for hacking.

2.3 Client Controls

Leadership at Tesla claims certain main safeguards manage Vehicle Software along with FOTA updates. This review will assess how well these measures work in practice. A structured approach to software creation and deployment is in place. This framework covers all phases of the development lifecycle.

Code must be checked by teammates before moving forward. Automated tools examine code both at rest and during execution. Advancing a build from testing to live use follows clear conditions. Cryptographic signing ensures firmware files carry a secure mark made with protected keys stored in specialized hardware. Since each vehicle receives updates, it checks this digital signature prior to installing, blocking anything that lacks a valid proof. Only when authentication passes is the update accepted for use inside the system.

Access to the firmware signing setup is tightly limited; multi-factor login is required. Developers aren't allowed to move their code into live systems, while those handling releases can't alter source files; this separation ensures checks are in place. Instead of combining roles, responsibilities are split to reduce risk.

A staged rollout uses a canary approach, updates first go to a limited set of test vehicles. Following that, they move to more employee-driven cars before full deployment across customer units. Instead of broad launches, changes expand step by step based on real-world feedback. System checks run automatically after each update to monitor how well installations complete. Performance data from the fleet helps spot issues early through continuous tracking.

A clear incident response strategy is available for FOTA issues. If problems arise, updates can be stopped fast using built-in tools; alternatively, a corrective update may be sent to affected vehicles, returning them to an earlier reliable version. Systems support quick action when deployment errors occur.

2.4 Audit Criteria

The audit will assess Tesla's controls using these set standards

Internal Policies and Standards:

- Tesla Internal Software Security Policy (TISSP-001)
- Tesla Firmware Release Management Procedure (TFRM-005)

- Tesla Incident Response Plan (TIRP-002)

Industry Standards and Frameworks:

- ISO/IEC 27001:2022 includes specific controls in Annex A - such as A.8.24, which focuses on secure development processes; A.8.31, dealing with safe coding practices; also relevant is A.5.24, addressing how incidents related to information security should be handled
- NIST Cybersecurity Framework (CSF) v1.1, specifically subcategories from the PR.IP, PR.DS, y DE.CM functions.
- COBIT 2019 goals include APO12 - handling risks - as well as DSS06, which focuses on overseeing operational controls within processes.

Automotive-Specific Guidelines:

- ISO/SAE 21434: Road vehicles - Cybersecurity engineering.
- UN Rule 155 sets common standards for vehicle certification related to cyber protection, plus systems managing those risks.

Regulatory Requirements:

- GDPR / CCPA / PIPL: As they relate to the privacy and security of data processed by vehicle software and during the update process.

2.5 Audit Schedule & Resourcing

The Vehicle Software and FOTA Management Audit takes place in Q1, using 160 auditor-days for completion.

Timeline:

- ➔ **Pre-Audit Planning (2 weeks):** Set up the audit approach. Collect first documents like policies and system layouts. Hold kick-off talks with main team members. Ask for early data sets used in testing samples.

- **Fieldwork (10 weeks):** Carry out audits using interviews or control checks, along with sample assessments and reviews of technical setups. Work takes place directly at selected development sites during this stage.
- **Reporting (3 weeks):** Combine insights, write a preliminary audit summary, hold a closing meeting with leaders to review outcomes, then include their comments before submitting the final version.
- **Wrap-up & handover (7 days):** Complete the report ahead of sharing, then start monitoring what managers do next.

Team Allocation:

- ★ **Audit Lead (Dana Hussain):** Managed the project's workflow while handling updates to stakeholders; reviewed documentation before submission - also responsible for drafting the final report.
- ★ **IT Controls Specialist (Aljazi Ali):** Emphasis lies on governance elements, assessing policies, checking SDLC procedures, while ensuring consistency with COBIT or ISO 27001 standards.
- ★ **Software Security Analyst (Noora Abdulrhman):** A technical specialist who checks CI/CD pipeline safety; assesses code review tools through systematic evaluation. She examines how source code access is controlled using role-based methods. Her work includes oversight of encryption key handling via policy compliance.
- ★ **Network & Systems Auditor (Manar Hussain)** checks the setup behind FOTA - examining server protection, dividing network parts in delivery systems, while also ensuring safe data links between cars and servers using TLS.

The team will collaborate directly alongside the VP of Vehicle Software as well as the Chief Information Security Officer (CISO), engaging both their groups to maintain smooth implementation.

2.6 Evidence Gathering Techniques

The audit uses various methods to collect data - combining observation, testing, and documentation review. These approaches help ensure findings are reliable while maintaining accuracy across different stages. Each technique supports the overall goal without unnecessarily overlapping

1. **Inspection:** Inspecting policy files, alongside software development lifecycle guides; examining change requests with records of code checks. Looking at digitally signed firmware versions, together with user permission settings, and reviewing post-incident summaries for compliance gaps.
2. **Observation:** Watching a trial or a real software launch helps check if the step-by-step deployment works properly. One way is to see whether system checks during rollout match what's expected. This method relies on live feedback rather than assumptions. It uses direct input from operational behavior instead of theoretical models. The focus stays on how things perform under actual conditions.
3. **Inquiry:** Talking to coders, release coordinators, site reliability engineers, or security staff helps clarify duties while providing background on documented processes.
4. **Re-performance:** A re-performance test involves picking some firmware versions at random. Then, an auditor follows one candidate from start to finish across the CI/CD process. The goal is to check whether key steps like code checks, safety scans, or digital

signatures were actually done. This method confirms if safeguards work as intended during deployment.

5. **Data Analysis:** Applying computer tools to review FOTA system logs, spotting irregularities, unsuccessful updates, or recurring signs of problems, while also checking how long it takes from approval to rollout.

3. Proposed Test of Controls Audit Procedures

When it comes to the five main client checks from Section 2.3, here's what testing steps we're suggesting. Each step specifies how many samples to pick, the method to use, what proof to look at, and exactly what the auditor needs to do.

Table 4: Detailed Test-of-Controls Procedures for Key Client Controls

Control	Sample and Technique	Evidence to Review	Auditor's Actions
1. Formalized Software Development and Release Policy	Sample: 30 software change records (e.g., Git commits/Jira tickets) selected randomly from the past 6 months. Technique: Inspection + Re-performance.	- Software Development and Release Policy. - Records of code reviews (e.g., pull request logs in GitHub/GitLab). - Reports from static/dynamic code analysis tools. - Change management tickets	- For each selected change, verify that a peer code review was completed and documented before merge. - Confirm that the code analysis tool ran and that critical/high-severity findings were addressed or formally accepted

		for production releases.	by management before release. - Trace the change from commit to the final production release build, verifying it passed through all required stages (dev, test, staging) as per the policy.
2. Cryptographic Signing and Verification	Sample: 10 distinct firmware binaries released to production in the past year. Technique: Inspection + Re-performance.	- Firmware signing procedure document. - HSM access logs and signing event logs. - The sampled firmware binary files. - Vehicle-side update verification logic (design documentation).	- Using a trusted external tool, verify the digital signature on each of the 10 sampled firmware binaries to confirm they were signed by Tesla's official key. - Inspect HSM logs to confirm that the signing events for the sampled binaries occurred and were authorized.

			- Review design docs to confirm the vehicle's update client is programmed to validate the signature and reject invalid ones.
3. Strict Access Control and Segregation of Duties	Sample: 25 user accounts with access to: a) source code repos, b) CI/CD admin console, c) firmware signing system. Technique: Inspection + Inquiry.	- User access lists for critical systems (Git, CI/CD, HSM). - HR records for role assignments. - Logs of privileged actions (e.g., code promotions, signing requests).	- For each sampled user, reconcile their system access with their job role in HR records to ensure appropriateness (principle of least privilege). - Verify that no single user has both the ability to write code and the ability to approve its production release or initiate the signing process. - Inspect logs for a sample of privileged actions to confirm they

			were performed by authorized individuals.
4. Staged Rollout and Health Monitoring	Sample: The last 5 major vehicle software releases. Technique: Inspection + Observation.	- Staged rollout policy document. - Deployment logs showing the progression of each release (internal fleet -> employee fleet -> public). - Vehicle health telemetry dashboards and alert logs from the monitored releases.	- For each of the 5 releases, trace the rollout path using deployment logs to confirm it followed the defined staged process. - Observe the health monitoring dashboard in operation (or review historical snapshots) to see how anomalies are detected. - Review logs for any instances where a rollout was paused or halted due to health monitoring alerts.
5. Incident Response and Rollback Capability	Sample: 2 recent FOTA-related incident reports (or conduct a	- FOTA Incident Response Plan.	- For the sampled incidents (or via a tabletop exercise),

	tabletop exercise if none exist). Technique: Inspection + Inquiry.	- Post-incident reports (PIR) from past events. - Technical documentation for the rollback mechanism. - Logs from a previous rollback event.	evaluate the response timeline and actions taken against the procedures in the IR plan. - Inquire with the SRE team about the process for executing a rollback and review logs from a past event to confirm it was executed successfully. - Verify that the rollback firmware images are themselves securely stored and signed.
--	---	--	---

All testing steps, outcomes, and changes are clearly written down in the audit files. Results get grouped by how risky or serious they are, and big problems go into the final report with tips on how to fix them.

4. The Audit Team

The IS Audit Team working on Tesla includes experienced members who bring different but matching skills. Roles are well set, qualifications outlined, while duties help carry out the audit smoothly. Each person's tasks fit together through clear expectations, making progress steady without unnecessary delays or confusion.

4.1 Audit Team Roles

Audit Team Leader (Dana Hussain) ensures the audit runs effectively; handles planning, costs, and deadlines. Communicates mainly with Tesla's top executives, along with the Audit Committee members. Goes over every audit document while guiding how results are reported, and also decides what issues matter most in the end.

IT Controls Expert (Aljazi Ali): Looks at governance, risk, and compliance during audits. Assesses how well top-level controls work, such as policies, risk methods, and SDLC oversight. Works to meet goals from COBIT and ISO 27001 standards.

Software Security Analyst (Noora Abdulrahman): Technical specialist in secure coding and system protection. Conducts thorough assessments of CI/CD workflows, examines code storage safeguards, handles flaw tracking processes, and implements encryption methods effectively. Offers practical knowledge using current dev tools and methodologies.

Network & Systems Auditor (Manar Hussain): Looks at the core systems supporting FOTA updates. Checks how secure the servers, network links, and cloud services are when sending

software. Examines firewall settings alongside intrusion detection setups. Also evaluates protection levels in data paths connecting cars to Tesla's central systems.

4.2 Audit Team Qualifications

The group includes members with official credentials alongside hands-on backgrounds suited for reviewing Tesla's advanced tech setup.

Certifications:

Dana Hussain (Lead) holds CISA and CISM certifications. With around 10 years in IT auditing, her work centers on tech firms along with manufacturers. Her background includes assessing system security across these industries, combining technical audits alongside risk evaluations.

Aljazi Ali works in controls. Certified by CISA and trained as an ISO 27001 auditor. Has spent seven years focusing on IT oversight, risk management, and compliance tasks. Expertise built through hands-on roles over multiple sectors.

Noora Abdulrahman works in software security, holding a GSSP certification from GIAC along with an OSCP credential through Offensive Security. She has spent around five years focusing on app security tasks rather than general IT roles. Her work includes hands-on penetration testing activities across various platforms. Her background combines practical fieldwork instead of only theoretical knowledge, giving her insight into real-world vulnerabilities that developers often overlook during coding phases.

Manar Hussain handles networks and systems; holds a CCNA Security plus a CCSP certification. With six years under her belt, she's worked on checking cloud setups alongside network defenses, mixing hands-on audits with technical oversight in real-world environments.

Relevant Experience:

The group has jointly worked on assessments of advanced tech setups such as internet-connected devices or apps built for the cloud, using varied evaluation methods.

Hands-on background in reviewing system development cycles, managing encryption keys along with digital certificates, also testing how teams handle security incidents.

Familiarity with rules in the car sector, especially changing requirements for digital security in vehicles.

4.3 Audit Team Responsibilities

The team handles every stage of the audit process,

1-Planning:

- Secures audit charter through management endorsement.
- All members take part in shaping the detailed audit plan by using their specific knowledge. One person's input builds on another's through focused adjustments. Each expert adds value where it matters most, guiding structure without repeating others work.
- Experts spot major threats and relevant safeguards in their areas.

2-Fieldwork:

- All members will carry out the audit steps, make sure records are complete, and share results quickly with the Lead.
- Runs regular check-in meetings while balancing what stakeholders expect; flags problems when required.
- Analysts carry out technical tests, also handling data evaluation.

3-Reporting:

- All members contributed draft segments focusing on their respective audit domains, each part built independently yet aligned overall.
- Coordinates the draft review, guides the closing meeting, and then prepares the final version for sharing.

- Controls Specialist: Links results to guidelines while using accepted criteria as reference.

4-Follow-up:

- Tracks how well managers follow through on planned actions, then updates the Audit Committee about results using clear summaries that show what's been done or still needs work.
- Progress details are shared regularly, so oversight remains informed without delay.
- Team members: Carry out further checks to confirm fixes were properly applied.

5. Additional Components

5.1 Conclusion and Recommendations

This report outlines a risk-focused IS Audit Plan along with a thorough Audit Program for Tesla, Inc. Aligned closely with Tesla's strategic goals, the approach responds to critical operational hazards tied to its leadership in electric transport, renewable power, and self-driving systems. Instead of broad coverage, it prioritizes key domains: Core Infrastructure, Manufacturing, Vehicle Software, and Autopilot AI to maximize relevance.

Through this focus, the audit activity delivers meaningful insights and confidence directly to senior leaders and the Board. The framework relies on established global benchmarks - such as ISO/IEC 27001, COBIT 2019, or the NIST CSF to support a thorough method for assessing safeguards. Instead of generic checks, the suggested review process for vehicle software and FOTA reflects targeted measures needed to examine intricate technologies central to Tesla's offerings.

To boost Tesla's control systems and ability to handle challenges, management should consider these broad suggestions:

- Create a clear structure for IT oversight by forming a team with top staff from Engineering, Manufacturing, IT, and Security. This group must come together every three months to go over audit results, monitor corrective actions, while also check how well the company handles new risks.
- Focus on ongoing control tracking: shift from one-off audits through the use of monitoring systems. Such tools deliver immediate insights into critical safeguards like constant scans for flaws in FOTA server setups, automatic reviews detecting role conflicts in SAP environments, or live oversight of who accesses AI model datasets.
- Improve oversight of external partners: With Tesla's expanding supply network and greater reliance on cloud platforms, upcoming audits need to cover key suppliers more thoroughly, particularly ones handling sensitive information or linked to car operations.
- Build a proactive threat detection system: Instead of only responding to threats, Tesla ought to create a specialized unit focused on finding hidden attackers using smart data analysis and real-time insights to spot intrusions that slipped past outer security layers, especially in car software systems or production infrastructure.

In short, putting this audit strategy into action alongside strong follow-up from leaders will help protect Tesla's resources, keep customers confident, and support steady technology progress. The Audit Committee and top executives should back the initiative, giving the required backing so auditors can carry it out effectively.

References

International Organization for Standardization. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements*.

ISACA. (2018). *COBIT 2019 Framework: Introduction and Methodology*.

ISACA. (2021). *CSX Cybersecurity Fundamentals Study Guide, 2nd Edition*.

National Institute of Standards and Technology (NIST). (2018). *Framework for Improving Critical Infrastructure Cybersecurity (Version 1.1)*.
<https://doi.org/10.6028/NIST.CSWP.04162018>

Tesla, Inc. (2023). *Tesla Master Plan Part 3*. Retrieved from
<https://www.tesla.com/blog/master-plan-part-3>

UNECE. (2021). *UN Regulation No. 155 - Uniform provisions concerning the approval of vehicles with regards to cybersecurity and cybersecurity management system*. United Nations Economic Commission for Europe.